Report

Cross Site Request Forgery

Suyash A Gunjal

What is Cross Site Request Forgery?

Cross Site Request Forgery is considered as one of top

vulnerability in today's web, where an untrusted website can force the user browser to send the unauthorized valid request to the trusted site.

Cross-Site Request Forgery (CSRF) is a type of web security vulnerability where an attacker tricks an authenticated user's browser into unintentionally sending unauthorized requests to a trusted web application. Since the user is already logged in, the application treats the malicious request as legitimate, allowing attackers to perform actions such as changing account details, transferring funds, or altering settings without the user's knowledge.

Prevention Points For CSRF:

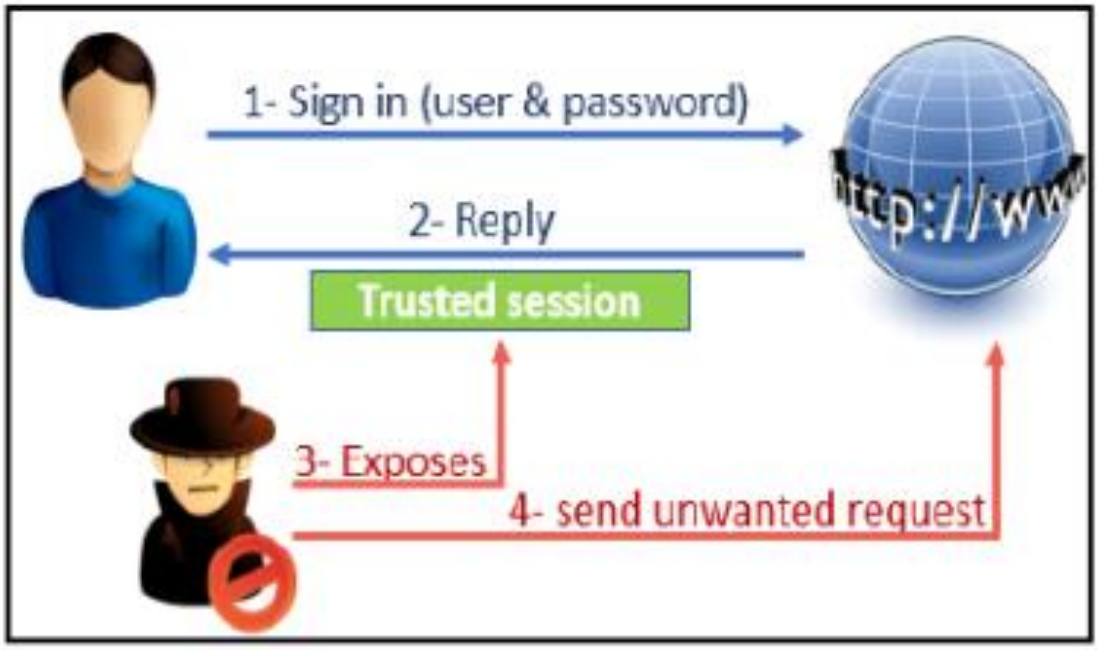
CSRF Tokens - Use unique, unpredictable tokens in forms and requests to verify authenticity.

SameSite Cookies - Set cookies with the SameSite attribute to block cross-origin requests.

Re-authentication - Ask users to re-enter passwords or OTPs for sensitive actions.

Verify Request Origin - Check request headers (Origin/Referer) to ensure they come from the same trusted domain.

Structure of Cross Site Request Forgery:



1. User signs in → Enters username & password on a trusted website.

2. Trusted session created → Website replies and keeps the user logged in.

3. Attacker exploits session → The attacker tricks the user (e.g., via malicious link).

4. Unwanted request sent → User's active session is misused to perform unauthorized actions.

Burp Project Intruder Repeater View Help

Burp Suite Community Edition v2025.7.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 ×

Send Cancel

Target: https://0a54008b04837af48f5b5fa9004a00e4.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
POST /my-account/change-email HTTP/2
Host: 0a54008b04837af48f5b5fa9004a00e4.web-security-academy.net
Cookie: session=9apaQEaAiSKX4PfYP8WgCee9lhzIN7UB
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101
Firefox/142.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 25
Origin: https://0a54008b04837af48f5b5fa9004a00e4.web-security-academy.net
Referer:
https://0a54008b04837af48f5b5fa9004a00e4.web-security-academy.net/my-account?id
=wiener
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
Te: trailers

email=test123%40email.com
```

Search 0 highlights

Response

Inspector

Request attributes	2
Request query parameters	0
Request body parameters	1
Request cookies	1
Request headers	20

Inspector Notes Custom actions

Ready

Event log All issues Memory: 356.6MB Disabled

25°C Clear Search ENG IN 20:35 26-08-2025

CYBERSAPIENS

Request

Pretty Raw Hex

```
1  POST /my-account/change-email HTTP/2
2  Host: 0a54008b04837af48f5b5fa9004a00e4.web-security-academy.net
3  Cookie: session=9apaQEaAiSKX4PfYP8WgCee9lhzIN7UB
4  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101
   Firefox/142.0
5  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6  Accept-Language: en-US,en;q=0.5
7  Accept-Encoding: gzip, deflate, br
8  Content-Type: application/x-www-form-urlencoded
9  Content-Length: 25
10 Origin: https://0a54008b04837af48f5b5fa9004a00e4.web-security-academy.net
11 Referer:
   https://0a54008b04837af48f5b5fa9004a00e4.web-security-academy.net/my-account?id
   =wiener
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
19
20 email=test123%40email.com
```

Search 0 highlights

References:

https://portswigger.net/web-security/csrf

https://www.researchgate.net/publication/281583832_Survey_on_Cross_Site_Request_Forgery_An_Overview_of_CSRF